

Siemens Firmware Attack Surface & Detection Brief

Scope: 2 installation media / ~957,125 unique hashes (DVD1 STEP7+WinCC = 686,425; DVD2 HSP+Tools = 270,700) across 6 architecture classes. Findings combine CVE/PSIRT research with direct examination of the extracted TIA Portal V21 workstation media (installers, embedded resources, HSP archives). PLC, SCALANCE, and RUGGEDCOM device firmware is **not extracted** — those groups are research-only and rely on Siemens ProductCERT, CISA, and third-party research (Claroty Team82, Forescout Vedere, Armis, Dragos).

Purdue layer mapping: TIA Portal engineering IDE (Group A), WinCC SCADA (Group B), and TIA Portal HSPs (Group C) live at **Purdue L3 (Site Operations)** — the engineering workstation + SCADA server tier. SIMATIC PLCs (Group D) sit at **Purdue L1 (Basic Controllers)**, with the F-CPU safety variants (S7-1500F) on the **Safety Systems** branch. SCALANCE switches/firewalls and RUGGEDCOM substation gear (Groups E/F) live at **Purdue L3.5 (IT/OT Boundary)**. See [purdue-l3-site-operations-brief.md](#), [purdue-l1-basic-controllers-brief.md](#), [purdue-safety-systems-brief.md](#), and [purdue-l35-it-ot-boundary-brief.md](#) for cross-vendor views.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. TIA Portal V21 engineering IDE (DVD1)	L3 Site Operations (EWS)	STEP7 Basic/Professional, STEP7 Safety, Openness API, Automation License Manager	Windows .NET/WPF + MSI/MSP installers, license daemon, project-file handlers	~686K hashes (workstation install tree)
B. WinCC SCADA / HMI server (in DVD1)	L3 Site Operations	WinCC Basic/Comfort/Advanced/Professional/Unified, Runtime, OPC UA server	Windows services (CCEServer, CCAgent), SQL Server backend, web client	subset of DVD1
C. TIA Portal HSPs + tools (DVD2)	L3 Site Operations	Hardware Support Packages, IntegrityValidator, SIMATIC CAX data	Signed .isp16 / .sis8 containers + .NET tooling	270,700 hashes
D. SIMATIC PLCs (S7-1500/1200/300/400)	L1 Basic Controllers (S7-1500F → Safety)	CPU 1500/1200/300/400, ET 200 distributed I/O	ADONIS RTOS (1500) / proprietary (1200) on PPC/ARM, S7comm/S7comm-Plus (102/TCP), PROFINET	research only

Class	Purdue layer	Products	Stack	Catalog depth
E. SCALANCE industrial switches	L2-L3.5 fabric (S615 firewall + W-700 at L3.5; XB/XC/XM/XR cell-area at L2)	XB-200, XC-200, XM-400, XR-500, S615 (firewall), W-700 (wireless)	Linux on MIPS/ARM, web UI, SNMP, SSH, Telnet	research only
F. RUGGEDCOM substation gear	L1/L2 substation network (IEC 61850 station/process bus); L3.5 mgmt plane	RSG2100, RST2228, RX1500, ROS / ROX II	ROS (proprietary) / ROX II (Linux), IEC 61850 stack	research only

Group A — TIA Portal V21 engineering IDE (workstation foothold) — Purdue L3 (Site Operations, EWS)

Direct attack surface (from the extracted DVD1 install tree):

MSI/MSP installers · Automation License Manager service (ALM, TCP/4410) · Openness API (.NET, project-file automation) · WCF endpoints for project access · SIMATIC Logon · project-file handlers (.ap21, .zap21) registered on the workstation

The engineering workstation is the **single highest-value pivot in an OT network** — it holds project files for every PLC and the credentials/certs to push logic. The Openness API is `.NET`-callable from PowerShell, which means any code-exec on the workstation = silent PLC reprogramming.

Confirmed CVEs / advisories:

CVE	CVSS	Product	Vector	Status on the firmware you have
CVE-2024-49775	7.8	TIA Portal (UMC)	Local privilege escalation via User Management Component	TIA V21 — verify UMC version shipped on DVD1
Siemens ProductCERT — TIA Portal Openness advisory index	7.x	TIA Portal Openness	Project file deserialization → code exec	applies to engineering host
Siemens ProductCERT — Automation License Manager advisory index	7.x	Automation License Manager	Local privilege escalation on ALM service	ALM is bundled in DVD1
Siemens ProductCERT — TIA Portal project-file advisory index	7.x	TIA Portal	Project-file path traversal class	older but patched class — check V21 regression

Top attack vector (MITRE ATT&CK ICS): [T0853 Scripting](#) via the Openness API → [T0843 Program Download](#) to push tampered logic to live PLCs. This is the Stuxnet shape, modernised — own the EWS, weaponise the vendor's own API.

Group B — WinCC SCADA (HMI server) — Purdue L3 (Site Operations)

Direct attack surface (DVD1 install tree + Siemens documentation):

```
CCEServer / CCAgent Windows services • WebNavigator IIS app • OPC UA server (TCP/4840) •
SQL Server backend (MSSQL Express bundled) • WinCC Unified web client (HTTPS/443)
```

WinCC is the historical Stuxnet target and remains the most-CVE'd HMI on the market. Unified moves it to a browser-based stack which has introduced fresh XSS / auth-bypass classes.

Confirmed CVEs / advisories:

CVE	CVSS	Product	Vector	Status
Siemens ProductCERT — WinCC web-client auth advisory class	9.x	WinCC	Improper auth in WinCC web client	applies V7.x; verify V21 bundle
Siemens ProductCERT — WinCC Unified Web Runtime advisory class	8.x	WinCC Unified	Path traversal in Unified Web Runtime	Unified is in DVD1
Siemens ProductCERT — WinCC installer DLL-hijack advisory class	7.8	WinCC	DLL hijack on installation	installer-time exploit — matches DLL-hijack class
Stuxnet (historical)	n/a	WinCC + S7	Hardcoded MSSQL credential + .DLL hijack in <code>s7otbxdx.dll</code>	the original; design lesson, not active CVE

Top attack vector (MITRE ATT&CK ICS): [T0859 Valid Accounts](#) on the WinCC SQL Server backend (Stuxnet's path) plus [T0832 Manipulation of View](#) by tampering tag values shown to the operator.

Group C — Hardware Support Packages (DVD2) — Purdue L3 (Site Operations)

Direct attack surface (from the extracted DVD2 archives):

HSPs are signed device-support bundles that the engineering workstation installs into TIA Portal to add or update device drivers. The risk is a **supply-chain HSP** — a tampered or maliciously crafted HSP that exploits the installer logic in TIA Portal itself.

- Signature verification on HSP install is the only barrier; any installer-side parser bug = code-exec on the EWS at admin privilege.
- The DVD2 tree also contains `IntegrityValidator`, the SIMATIC field tool used to verify PLC firmware integrity — if attackers tamper this tool, they hide their own PLC implants.

Top vector: Tampered HSP delivered via phishing or vendor-portal compromise → code-exec inside TIA Portal → silent push to PLCs (chains into Group A's T0843).

Group D — SIMATIC PLCs (research only) — Purdue L1 (Basic Controllers; S7-1500F → Safety)

Direct attack surface (vendor documentation + Claroty/Forescout research; firmware not extracted):

- S7comm (TCP/102) and S7comm-Plus on S7-1500/1200 — proprietary, has been reverse-engineered repeatedly.
- PROFINET DCP (L2, no auth) — device discovery + IP reassignment.
- Web server on CPU (HTTP/HTTPS), optional OPC UA server.
- "Native PLC" code download path — S7-1500 added per-block signing but the engineering credentials still gate it.

Confirmed CVEs / advisories:

CVE	CVSS	Product	Vector	Status
CVE-2022-38465	9.3	S7-1200/1500	Hardcoded global private key → bypass protected communication & native-code load (Claroty Team82)	research-only; check fielded firmware
Siemens ProductCERT — S7-1500 CPU web-server DoS advisory class	7.5	S7-1500 CPU	Web server DoS	confirm fielded patch level
CVE-2020-15782	8.1	S7-1500	Memory-protection bypass → native code (Claroty)	landmark research, patched but verify
CVE-2024-3596	9.0	RADIUS BlastRADIUS — affects SIMATIC products using RADIUS	MITM auth bypass	check SCALANCE/SIMATIC RADIUS-enabled deployments

Top attack vector (MITRE ATT&CK ICS): [T0843 Program Download](#) via engineered S7comm-Plus session (post-CVE-2022-38465 the global key bypass made this drastically easier; assume legacy firmware exists in fielded plants), often paired with [T0833 Modify Control Logic](#).

Group E / F — SCALANCE switches and RUGGEDCOM (research only) — Purdue L2–L3.5 fabric (SCALANCE cell-LAN at L2, S615 firewall at L3.5; RUGGEDCOM IEC 61850 substation bus at L1/L2 with L3.5 mgmt plane)

ProductCERT publishes SCALANCE advisories roughly monthly. The recurring classes:

CVE	CVSS	Product	Vector
Siemens ProductCERT — SCALANCE/RUGGEDCOM SSH-web advisory class	7.x	SCALANCE / RUGGEDCOM SSH/web	Multiple auth & command-injection issues
Siemens ProductCERT — SCALANCE W-700 SNMP advisory class	7.5	SCALANCE W-700	SNMP DoS
Siemens ProductCERT — SCALANCE X-200 web-UI cmd-injection advisory class	8.8	SCALANCE X-200	Web UI cmd injection (auth)
CISA — RUGGEDCOM ROS ICS Advisories index	n/a	RUGGEDCOM ROS	Multiple

RUGGEDCOM ROX II (Linux) and ROS (proprietary) advisories appear less often but tend to be high-CVSS when they do (substation gear, IEC 61850 stacks). Treat as priority-extract candidates.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Sysmon on EWS (TIA Portal hosts)	EventID 1 ProcessCreate where ParentImage= <code>Siemens.Automation.*</code> AND child = <code>powershell.exe / cmd.exe / rundll32.exe</code>	Openness-API abuse, scripted PLC push	T0853 Scripting
2	Sysmon on EWS	EventID 7 ImageLoad — non-Siemens DLLs loaded by <code>Siemens.Automation*.exe</code> OR <code>CCEServer.exe</code>	DLL-hijack class (WinCC installer DLL-hijack family)	T1574.001 (Enterprise)
3	Windows Security log on EWS	Logon to <code>Automation License Manager</code> service from non-engineer accounts	ALM LPE attempts	T0859 Valid Accounts
4	Network IDS (Zeek/Suricata)	S7comm-Plus session from outside EWS VLAN to PLC TCP/102	Unauthorised PLC programming attempts	T0843 Program Download
5	Network IDS	PROFINET DCP <code>Set</code> (IP/Name reassignment) from any non-engineer MAC	PLC hijack / topology rewrite	T0856 Spoof Reporting Message
6	Network IDS	OPC UA <code>WriteValue</code> to WinCC tags from non-HMI hosts	HMI tag tamper	T0836 Modify Parameter
7	WinCC audit log	<code>User logon failed X N then success</code> , OR <code>Project loaded</code> outside maintenance window	Brute force / unauthorised project load	T0812 Default Credentials
8	Siemens ProductCERT advisory feed	New SSA-* matching deployed PLC/SCALANCE FW	Patch-window prioritisation	n/a (intel)

Secondary:

- Firewall: any egress from PLC/SCALANCE management VLAN to non-RFC1918 — PLCs and switches should never originate outbound traffic to the internet.
- Siemens has native syslog on SCALANCE, S7-1500 (CPU diagnostic buffer over syslog), and WinCC — turn on `audit`, `security`, and `firmware-update` categories and forward to the SIEM.
- SIMATIC PLC diagnostic buffer: alert on `Module replaced`, `Firmware updated`, `Operating mode changed to STOP` outside maintenance windows — the firmware-updated case maps to [T0857 System Firmware](#).
- ProductCERT publishes second Tuesday of each month — schedule a SIEM job to re-evaluate IOC/version coverage that morning.

Process-anomaly signals (OT-native detection):

- Unscheduled CPU mode transition RUN→STOP (or STOP→RUN) on an S7-1500 → likely [T0858 Change Operating Mode](#).
- Cycle-time drift > 10% on a steady-state PLC block → control-logic tamper precursor ([T0833 Modify Control Logic](#)).
- New OB (organization block) or DB (data block) appearing on a CPU outside engineering change-control → silent reprogramming.

Specific zero-day-ish concerns for your dataset

1. **TIA Portal V21 is freshly released; UMC and Openness components carry forward from V19/V20.** CVE-2024-49775 (UMC LPE) and the Openness deserialization advisory class need explicit verification against the exact UMC/Openness DLL versions shipped on DVD1. The hash catalog is the gold source — pin the UMC DLL SHA256 and watch ProductCERT for any V21-specific successor advisory.
2. **DVD2 HSP supply-chain risk.** HSPs are the single most-trusted file type a TIA Portal admin will double-click outside the main installer. A tampered HSP that triggers a parser bug in the HSP installer = code-exec at admin on every EWS that installs it. Inventory HSP SHA256s from the DVD2 extract and treat any HSP delivered through email or USB as untrusted by default.
3. **CVE-2022-38465 global-key fallout on fielded S7-1500/1200.** The Claroty disclosure invalidated the trust model of every pre-patch CPU. Even though firmware isn't in your extract, the engineering workstation **is** — verify the EWS isn't still configured to talk to legacy firmware versions, because any attacker on the EWS can downgrade or coexist with those legacy CPUs and silently push native code.
4. **WinCC Unified browser stack is a newer attack surface than classic WinCC.** Treat any Unified-specific advisory as a higher-priority patch than equivalent classic-WinCC advisories — browser-served HMI introduces XSS and auth-bypass classes that the classic stack never had.

Sources

- [Siemens ProductCERT advisory index](#)
- [CVE-2024-49775 — TIA Portal UMC LPE](#)
- [CVE-2022-38465 — S7-1200/1500 global private key \(Claroty\)](#)
- [CVE-2020-15782 — S7-1500 memory-protection bypass \(Claroty\)](#)

- [CVE-2024-3596 — BlastRADIUS](#)
- [Claroty Team82 — Race to Native Code Execution on S7-1500](#)
- [CISA ICS Advisories — RUGGEDCOM index](#)
- [Fore Scout Vedere — OT:ICEFALL research](#)
- [Dragos — Industroyer2 analysis](#)
- [Armis — research index](#)
- [MITRE ATT&CK for ICS — T0843 Program Download](#)
- [MITRE ATT&CK for ICS — T0833 Modify Control Logic](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0857 System Firmware](#)
- [MITRE ATT&CK for ICS — T0858 Change Operating Mode](#)
- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)